compensar | fundación universitaria

Seguridad de la Información

Primer Taller

Experimenta y conecta con el mundo empresarial

Verificación

Asegurarse que todas las herramientas estén instaladas.

```
# En Kali Linux, todo viene preinstalado. En Ubuntu, instalar lo necesario:
sudo apt update
sudo apt install -y nmap lynis chkrootkit rkhunter clamav whois dnsutils
```

Primer Punto

Aprender a usar Nmap para descubrir hosts, puertos, servicios y sistemas operativos

a) **Descubrimiento de Host Activos**

Escaneo de ping para ver qué dispositivos responden en nuestra red local. Esto simula la fase inicial de reconocimiento

```
sudo nmap -sn 192.168.1.0/24
```

¿Cuántos hosts activos se encontraron? ¿Qué direcciones IP y MAC aparecen? ¿Podemos identificar algún fabricante por la MAC?

b) **Escaneo de Puertos y Servicios**

Una vez identificado un objetivo (se usará localhost o 127.0.0.1), escanearemos los puertos abiertos y los servicios que corren en ellos

```
# Escaneo de puertos comunes y detección de versiones de servicios
nmap -sV 127.0.0.1

# Escaneo más agresivo para detectar sistema operativo (requiere sudo)
sudo nmap -O 127.0.0.1
```

¿Qué puertos están abiertos en tu máquina? ¿Qué servicios y versiones están asociados a esos puertos? ¿Qué sistema operativo cree Nmap que estamos usando? ¿Coincide con la realidad?

c) **Uso de Scripts de Nmap (NSE)**

Ejecutar un script básico de seguridad, como el que comprueba si hay vulnerabilidades comunes

```
# Ejecutar scripts de vulnerabilidad básicos en localhost
nmap --script vuln 127.0.0.1
```

El script vuln busca vulnerabilidades conocidas. ¿Ha encontrado alguna? ¿Por qué crees que es útil (o no) este tipo de escaneo?

d) Escaneo con diferentes técnicas de sincronización (Timing Templates)

Comando:
```
nmap -T0 -sS 127.0.0.1
```
Paranoid

Comando:
```
nmap -T4 -sS 127.0.0.1
```
Agressive

¿Se nota alguna diferencia en la velocidad? ¿Por qué un atacante usaría un template lento (T0 o T1) en lugar de uno rápido (T4 o T5)?

e) Detección de puertos filtrados con escaneo TCP SYN (Stealth Scan).

```
sudo nmap -sS -p 80,443,22,25,110,143,8080 127.0.0.1
```

Observar el estado de los puertos: open, closed o filtered. ¿Qué cree que significa "filtered"? ¿Qué dispositivo en la red (real o simulado) podría estar causando ese estado?

f) Captura de banners de servicios.

Comando:

```
nmap -sV --version-intensity 9 127.0.0.1
```

Compara la salida con el escaneo –sV normal. ¿Qué información adicional obtuviste? (Ejemplo: versión exacta del servidor web, opciones de SSH, etc.)

g) Uso de scripts específicos para servicios concretos.

Comando:

Si no tiene un servidor web en localhost, pueden levantar uno rápido con:

```
python3 -m http.server 8080
```

Este se abre con un nuevo terminal.

```
nmap -sV --script http-title,http-server-header,http-methods -p 8080 127.0.0.1
```

¿Qué información ha extraído Nmap sobre el servidor web? (Título de la página, cabecera del servidor, métodos HTTP permitidos como GET, POST, etc.). ¿Por qué es peligroso que un atacante sepa que métodos como PUT o DELETE están habilitados?

Segundo Punto

Auditoría Local con Lynis, desarrollar el escaneo de seguridad con el siguiente comando:

```
# Ejecutar lynis en modo auditoría (necesita sudo para ser efectivo)
sudo lynis audit system
```

Análisis de Resultados:

Buscar la sección: `[+] Warnings`

¿Qué tipo de recomendaciones de seguridad aparecen? (Ej. falta de un firewall, configuraciones de SSH, etc.).

Buscar la sección: `[+] Suggestions`

¿Cuál es la sugerencia más crítica que ha encontrado Lynis?

Lynis asigna una un "hardening index" (índice de endurecimiento). ¿Qué puntuación ha obtenido tu sistema? ¿Cómo podrías mejorarla?

Tercer Punto

Detección básica de malware teniendo como objetivo como la introducción de técnicas y herramientas sencillas para detectar posibles infecciones.

a) Búsqueda de Rootkits

```
# Buscar rootkits con chkrootkit
sudo chkrootkit

# Actualizar la base de datos de rkhunter y ejecutar una comprobación
sudo rkhunter --update
sudo rkhunter --check --skip-keypress
```

¿Ha encontrado algún archivo infectado o alguna advertencia? “rkhunter” suele dar muchas advertencias falsas. Buscar la sección de advertencias en rojo. ¿Cuál es el contexto de esas advertencias?

b) **Análisis de Correcciones de red**

Un malware a menudo intenta comunicarse con un servidor de comando y control (C2). Se verán las conexiones activas.

```
# Ver todas las conexiones de red y programas asociados (como netstat)
sudo netstat -tupan
```

Observar la columna "Foreign Address" (dirección remota). ¿Visualiza alguna conexión establecida con una IP o dominio que no reconozca? ¿Qué proceso (PID/Program name) es el responsable

c) **Escaneo con Antivirus**

ClamAV es un antivirus de código abierto. Podemos escanear un directorio específico en busca de firmas de virus.

```
# Actualizar firmas de virus (puede tardar)
sudo freshclam
# Escanear el directorio personal del usuario
clamscan -r /home/usuario
```

IMPORTANTE

Desarrollar la explicación del paso a paso bien detallado en GitHub, donde se visualice la lógica utilizada, fotos, explicación de cada miembro del equipo de los puntos.

En el repositorio de GitHub se visualizará que todos aporten información por medio de la métrica denominada Insigths.

Mostrar los pantallazos de cada uno de los procesos y subirlos al github.